

The seal of the University of Coimbra is a circular emblem. It features a central figure, likely a saint or scholar, seated and holding a book. The figure is surrounded by a decorative border containing the text 'UNIVERSITAS COIMBRIGENSIS' and 'MDCCCXXXIII' (1833).

Security Auditing

Lesson#1

The need for Information Systems Security Compliance

School year 2025/2026

Master in Informatics Security (MSI) / Master in Informatics Engineering (MEI)

Informatics Engineering Department

University of Coimbra



Learning Objective

Describe the role of **Information Systems Security (ISS)** compliance in organizations.



Key Concepts

- ISS and **compliance** in organizations
- The differences between ISS **audits** and **assessments**
- The process of a risk-based approach to IT security management
- The relationship between **compliance**, **risk management**, and **governance**
- The consequences of not adhering to **compliance laws**



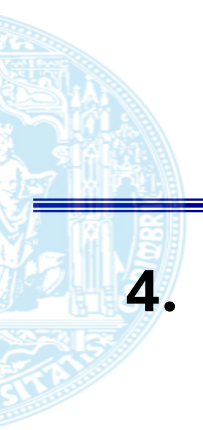
What is an IT Security Assessment?

- A key activity that involves the management of risk
- Involves a risk-based approach to managing information security



Risk-based Approach to Information Security Management

1. Categorizing the information system, giving consideration to the related data and the **impact as a result of an incident**
2. Selecting a **baseline set of controls** based on the previous categorization and **supplementing the baseline** as appropriate
3. Implementing and documenting the **security controls**



Risk-based Approach to Information Security Management (Cont.)

4. **Assessing the security controls** to ensure they are producing the desired results
5. **Authorizing the operation** of the information system based on an acceptable level of risk
6. **Monitoring the security controls** continuously



IT Security Assessment

- Should produce information required to:
 - **Identify weaknesses** within the controls implemented on information systems
 - Confirm that previously identified weaknesses have been **remediated or mitigated**
 - **Prioritize** further decisions to mitigate risks
 - Provide **assurance** so that associated **risks** are **accepted and authorized**
 - Provide support and planning for **future budgetary requirements**



Types of Assessments

Network security
architecture

Review of security
policies,
procedures,
practices

Vulnerability
scanning and
testing

Physical security

Social engineering

Applications

Security risks



What Is an IT Security Audit?

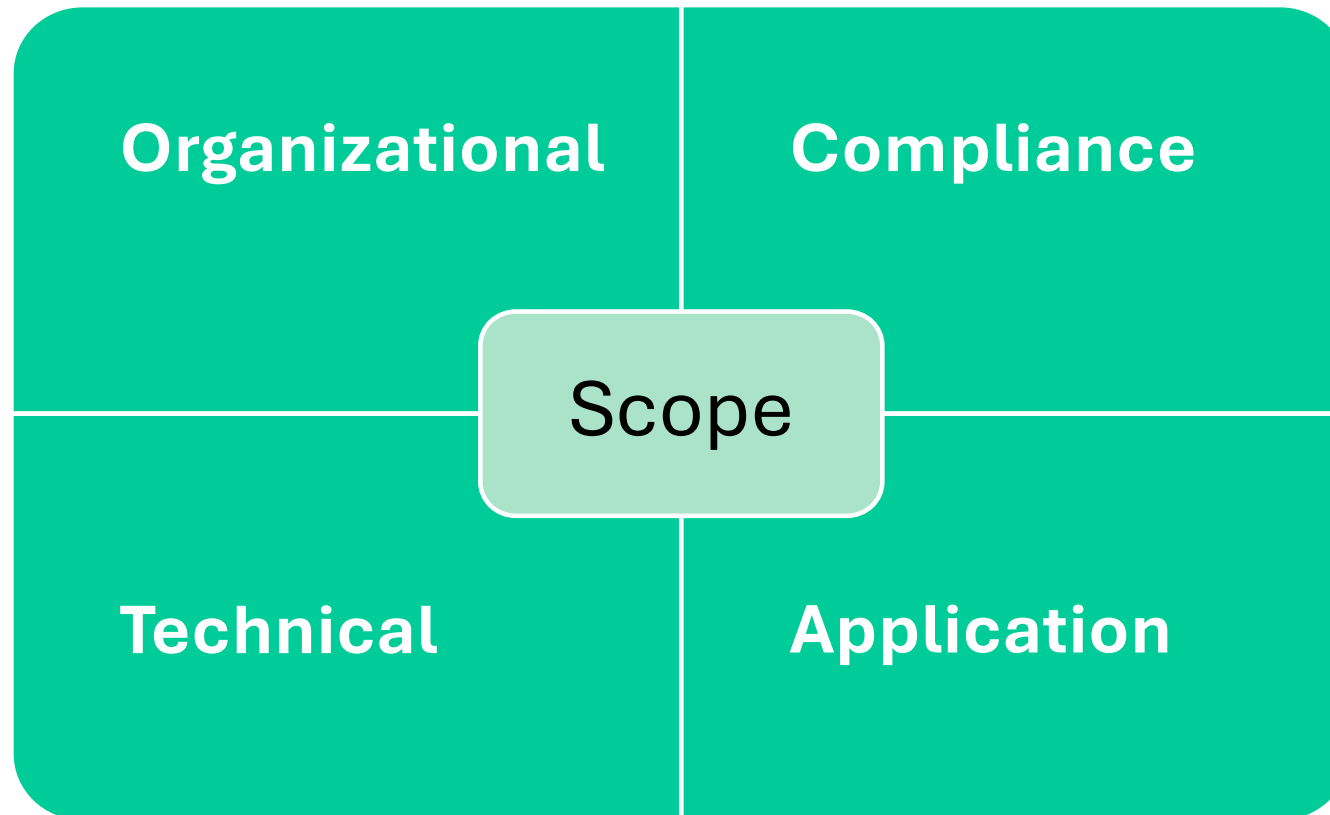
- An **independent assessment** of an organization's internal **policies, controls, and activities**
- You use an audit to:
 - Assess the presence and **effectiveness of IT controls**
 - Ensure that those **controls** are **compliant** with stated **policies**
 - Provide reasonable assurance that organizations are **compliant with applicable regulations** and other **industry requirements**



Common Types of Audits

Financial	• Determines whether an organization's financial statement reflects financial position of company
Compliance	• Determines adherence to applicable laws, regulations, and industry requirements
Operational	• Reviews adherence to policies, procedures, and operational controls
Investigative	• Investigates records and processes based on suspicious activity or alleged violations
Information technology	• Addresses IT system risk exposures

Scope of a Security Audit





An Effective IT Security Audit Program

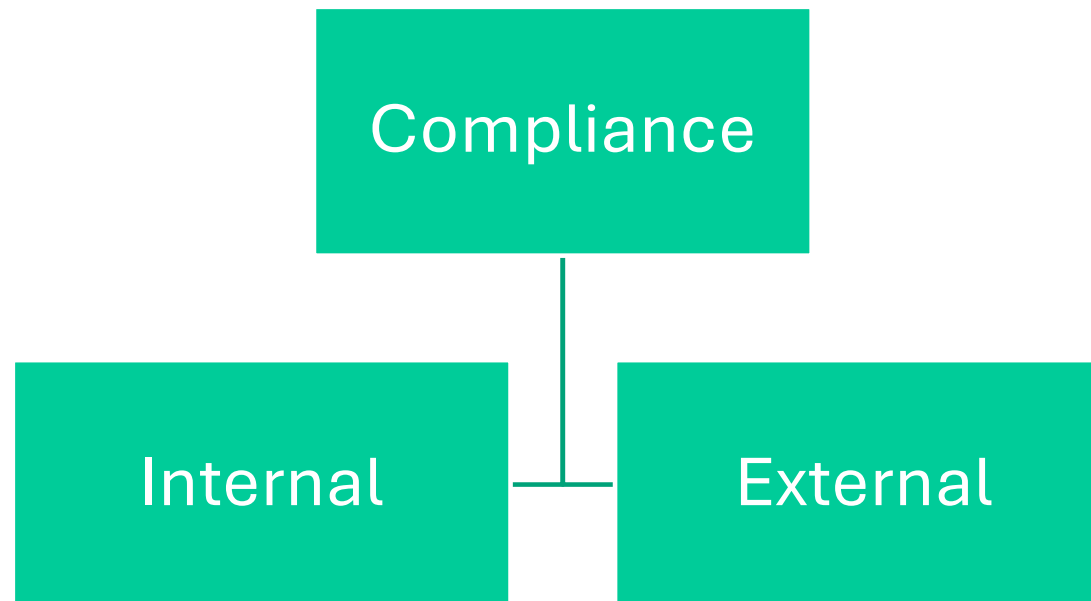
- An effective IT security audit program should accomplish the following goals:
 - Provide an **objective and independent review** of an organization's **policies**, information systems, and **controls**.
 - Provide reasonable **assurance** that appropriate and effective **IT controls are in place**.
 - Provide **audit recommendations** for both **corrective** actions and **improvement** to controls.



What Is Compliance?

- Merriam-Webster Online dictionary:
 - “The act or process of complying to a desire, demand, proposal, or regimen or to coercion.”
- To comply is “to **conform**, submit, or adapt as required or requested.”

Internal and External Compliance





Meeting Compliance

Interpret the regulation and how it applies to the organization.

Identify the **gap** or determine where the organization stands with the compliance mandate.

Devise a plan to close the gap.

Execute the plan.



Risk Management, Compliance, and Governance

- **Risk management** seeks to mitigate risk through controls.
 - For example, an organization identifies, evaluates, and takes action to lessen its risk.
- **Compliance** helps risk management by verifying that the desired controls are in place.
- **Governance** seeks to better run an organization using complete and accurate information and management processes or controls.



How Does an Audit Differ from an Assessment?

Audit	Outcomes	Assessment
Clear-cut; pass or fail	Failure	Assess and make improvements
Blame placed on specific individuals or groups	Blame	Nonattributive; individuals aren't responsible for poor findings
Often have negative consequences; penalties; creates sense of fear	Consequences	Identifies gaps to improve security and achieve goals



Audit Characteristics

Audit Characteristics

Auditors never audit applications, processes, systems they designed or created

Independent evaluations

Rigorous approach; follows accepted principles; must be qualified

Certification or confirmation received upon passing

Concerned about past results and performance



Why are Governance and Compliance Important?

- **Internal compliance** to corporate policies is **critical to success of business**
- Compliance embraces the **organizational mission**; noncompliance can harm or impede business
- **Regulatory compliance:**
 - Protects organization's **reputation and integrity**
 - Considers the **interests of the consumer** and shareholders
 - Has a farther-reaching **economic impact** on ensuring **public confidence** in organizations and capital markets



Enron Case Study

■ Enron Corporation:

- Was a U.S.-based energy company (**seventh largest company in U.S.**)
- Largest trader of natural gas and electricity
- Collapsed in 2001 and filed bankruptcy; largest bankruptcy in history at the time
- Collapse was a result of a complex and methodical accounting scandal
- **Thousands of employees were laid off**, lost their life savings plans
- Shareholders saw a **loss of \$11 billion**



Enron Case Study (Cont.)

■ Arthur Andersen:

- Enron's auditing firm
- Had attested to Enron's financial health for years, despite widespread fraud and hidden losses at Enron
- Assisted Enron in deal structuring and other consultative practices
- Was eventually convicted of obstruction of justice as a result of shredding paper documents and destroying electronic documents related to Enron
- Involvement with Enron led to discovery of other audit discrepancies, including those at WorldCom



Enron Case Study (Cont.)

■ Investigative findings:

- Enron had reduced its tax payments and inflated its income and profits.
- Enron had increased its stock price and credit ratings.
- Enron had hidden losses in off-balance sheet subsidiaries.
- Enron employees funneled money to themselves and acquaintances.
- Enron's financial condition was misrepresented in public reports.



Enron Case Study (Cont.)

- Failures of Enron board of directors:
 - Not being involved in the examination of terms related to moving debt off the company's balance sheets
 - Missed the chance to uncover fundamental flaws in the accounting practices at the company
 - “Systematically attempted to misrepresent the Company's financial condition”
- Scandal resulted in **new regulations** and legislation being enacted, including the **Sarbanes-Oxley Act**



Enron Case Study Questions

- How might a **control framework for IT** that is more closely aligned with business processes have prevented this?
- How could **adequate controls on IT systems** and financial applications have helped?
- Do you think that controls designed to prevent or detect fraud were in place?
- How important is the monitoring of such controls, and how should access be controlled?



What If an Organization Does Not Comply with Compliance Laws?

- Noncompliance can result in:
 - Fines
 - Jail time
 - Operational consequences
 - Example: Payment-card operational restrictions and loss of card-processing privileges for not complying with PCI DSS



Summary

- ISS and compliance in organizations
- The differences between ISS audits and assessments
- The process of a risk-based approach to IT security management
- The relationship between compliance, risk management, and governance
- The consequences of not adhering to compliance laws